

Rapport d'analyse de risques cybersécurité

Centre Médical Saint-Antoine

Méthode EBIOS Risk Manager

Objet du livrable : identifier les risques numériques les plus crédibles pour le centre médical, qualifier leurs impacts métier et proposer un plan de traitement priorisé, réaliste et exploitable par la direction.

Classification : confidentiel – diffusion limitée à la direction et aux parties prenantes autorisées

Realisé par KOMAN JOSEPH

Table des matières

1	Synthèse exécutive	2
2	Contexte et périmètre	3
2.1	Présentation du Centre Médical Saint-Antoine	3
2.2	Périmètre métier retenu	3
2.3	Périmètre technique retenu	3
3	Méthodologie	5
4	Atelier 1 – Cadrage et socle de sécurité	6
4.1	Objectif de l'atelier	6
4.2	Valeurs métier et biens supports	6
4.3	Échelle de gravité retenue	6
4.4	Événements redoutés	6
4.5	Socle de sécurité existant	7
5	Atelier 2 – Sources de risque	8
5.1	Objectif de l'atelier	8
5.2	Cartographie des sources de risque	8
5.3	Objectifs visés associés	8
5.4	Couples source de risque / objectif visé	9
6	Atelier 3 – Scénarios stratégiques	9
6.1	Objectif de l'atelier	9
6.2	SS1 – Rançongiciel via phishing	9
6.3	SS2 – Compromission via prestataire	10
6.4	SS3 – Exposition par négligence interne	10
6.5	Synthèse des scénarios stratégiques retenus	10
7	Atelier 4 – Scénarios opérationnels	10
7.1	Principe de lecture	10
7.2	SO1 – Rançongiciel via phishing CPAM	10
7.3	SO2 – Compromission via prestataire	12
7.4	SO3 – Exposition par négligence interne	13
7.5	Synthèse de l'évaluation des risques	13
8	Atelier 5 – Plan de traitement	14
8.1	Objectif de l'atelier	14
8.2	Modes de traitement retenus	14
8.3	Plan de traitement pour SO1 – Rançongiciel via phishing	14
8.4	Plan de traitement pour SO2 – Compromission via prestataire	14
8.5	Plan de traitement pour SO3 – Exposition par négligence interne	15
8.6	Risque résiduel estimé et décision d'acceptation	15
9	Conclusion et recommandations	16
10	Annexes	17
10.1	Références institutionnelles	17
10.2	Techniques MITRE ATT&CK utilisées	17
10.3	Glossaire court	17

1 Synthèse exécutive

Le Centre Médical Saint-Antoine a mandaté une analyse de risques cybersécurité selon la méthode **EBIOS Risk Manager de l'ANSSI**. L'objectif de cette mission est d'identifier les principales menaces pesant sur l'activité du centre et de définir un plan d'action priorisé permettant de réduire son exposition aux risques numériques.

Trois scénarios majeurs ont été identifiés : une attaque par **rançongiciel via phishing**, évaluée à un niveau de risque **critique** ; une **compromission via un prestataire informatique**, évaluée à un niveau de risque **élevé** ; et une **exposition de données résultant d'une négligence interne**, également évaluée à un niveau de risque **élevé**. Ces trois scénarios pourraient gravement compromettre la continuité des activités du centre, entraîner une exposition de données de santé, provoquer des sanctions de la CNIL et porter durablement atteinte à la confiance des patients.

Au total, **15 mesures de sécurité prioritaires** ont été définies, dont **11 mesures à engager en priorité**. La mesure la plus critique concerne la migration des sauvegardes vers un prestataire certifié **HDS**, la solution actuellement utilisée étant présentée dans le cas d'étude comme non conforme aux exigences applicables à l'hébergement de données de santé.

Le coût total estimé du plan de remédiation s'élève à environ **12 000 € pour la première année**. Cet investissement doit être mis en perspective avec le coût potentiel d'un incident majeur, notamment d'une attaque par rançongiciel, estimé dans le cadre de cette étude à environ **250 000 €** pour une organisation du secteur de la santé.

Recommandation à la direction

Il est recommandé à la direction de valider le plan d'action proposé, de désigner un référent sécurité interne chargé de son pilotage et d'engager la mise en œuvre des mesures classées **P1 dans un délai maximal de 60 jours**.

2 Contexte et périmètre

2.1 Présentation du Centre Médical Saint-Antoine

Le Centre Médical Saint-Antoine est un centre de santé pluridisciplinaire situé à Lyon, fondé en 2008. Il regroupe huit médecins, dont des généralistes et des spécialistes, et suit environ 3 000 patients actifs. L'organisation repose sur une structure réduite : huit médecins, deux secrétaires médicales et un cabinet comptable externe.

Malgré cette taille limitée, le centre manipule quotidiennement des données sensibles : données de santé, informations administratives, données de facturation, flux de télétransmission et éléments liés au tiers payant. Le système d'information occupe donc une place centrale dans la continuité des soins et dans la relation avec les patients.

2.2 Périmètre métier retenu

Le périmètre métier couvre les activités nécessaires au fonctionnement quotidien du centre :

- consultations médicales sur place ;
- téléconsultations ;
- gestion des dossiers patients et du dossier médical partagé ;
- prise de rendez-vous, notamment via Doctolib ;
- télétransmission à l'Assurance Maladie ;
- facturation, tiers payant et pilotage administratif courant.

La comptabilité externe, assurée par un cabinet tiers, est considérée hors périmètre principal. Elle reste néanmoins prise en compte comme dépendance, car elle peut avoir un impact sur les données administratives et financières.

2.3 Périmètre technique retenu

Le périmètre technique comprend les éléments suivants :

- le logiciel Hellodoc installé sur un serveur local ;
- les postes Windows utilisés par les médecins et le secrétariat ;
- la messagerie du personnel ;
- l'accès Internet du centre ;
- Doctolib et le site web vitrine ;
- les mécanismes de télétransmission ;
- les sauvegardes sur disque externe ;
- les sauvegardes cloud ;
- les comptes utilisateurs et les éventuels accès distants des prestataires ;
- le réseau Wi-Fi unique utilisé par le personnel et les patients.

Les terminaux personnels des médecins ne sont pas inclus dans le périmètre principal, car ils ne sont pas considérés comme pleinement maîtrisés par le centre. Leur usage éventuel reste toutefois un point

d'attention.

3 Méthodologie

La méthode utilisée est **EBIOS Risk Manager**, méthode française de référence portée par l'ANSSI pour identifier, comprendre et traiter les risques numériques propres à une organisation. Elle combine une approche par conformité, centrée sur le socle de sécurité, et une approche par scénarios, centrée sur les sources de risque, leurs objectifs et les chemins d'attaque plausibles.

L'étude est structurée selon les cinq ateliers EBIOS RM :

1. **Atelier 1 – Cadrage et socle de sécurité** : identification des valeurs métier, des biens supports, des événements redoutés et des écarts au socle de sécurité.
2. **Atelier 2 – Sources de risque** : sélection des sources de risque crédibles et des objectifs visés associés.
3. **Atelier 3 – Scénarios stratégiques** : construction de chemins d'attaque de haut niveau dans l'écosystème du centre.
4. **Atelier 4 – Scénarios opérationnels** : détail des modes opératoires, enrichis ici par un mapping MITRE ATT&CK.
5. **Atelier 5 – Traitement du risque** : définition des mesures, des priorités et du risque résiduel.

Dans le présent rapport, l'atelier 4 utilise le référentiel **MITRE ATT&CK** comme grille de lecture technique. Ce référentiel ne remplace pas EBIOS RM ; il permet de décrire les techniques adverses de manière normalisée : phishing par pièce jointe, ouverture d'un fichier malveillant, usage de comptes valides, propagation via partages Windows, compromission de chaîne d'approvisionnement, exfiltration ou chiffrement de données pour impact.

Cette combinaison EBIOS RM + MITRE ATT&CK permet de produire un livrable lisible par la direction tout en restant exploitable par un prestataire technique. Elle est adaptée au contexte du Centre Médical Saint-Antoine, où la priorité est de décider rapidement sur des mesures concrètes plutôt que de produire une documentation théorique difficile à maintenir.

4 Atelier 1 – Cadrage et socle de sécurité

4.1 Objectif de l'atelier

L'atelier 1 vise à poser le cadre de l'étude : valeurs métier, biens supports, événements redoutés, gravité des impacts et état du socle de sécurité existant. Il constitue la base de tout le raisonnement EBIOS RM, car les scénarios suivants doivent rester reliés aux activités réelles du centre.

4.2 Valeurs métier et biens supports

Valeur métier	Type	Description	Biens supports
Dossiers patients	Information	Données médicales et historique de prise en charge des patients	Hellodoc, serveur local, postes utilisateurs, sauvegardes disque et cloud
Consultations	Processus	Organisation et réalisation des rendez-vous entre patients et médecins	Hellodoc, postes médecins, accès Internet, agendas
Télétransmission Sécu	Processus	Transmission des feuilles de soins, remboursements et gestion du tiers payant	Logiciel Hellodoc, connexion Internet, lecteur de carte Vitale
Prise de rendez-vous	Processus	Gestion des disponibilités et accès au service via Doctolib	Doctolib, site web vitrine, agendas locaux
Réputation du centre	Information	Image du centre, crédibilité et confiance accordée par les patients	Avis Google, page Doctolib, retours patients, bouche-à-oreille
Données financières	Information	Informations liées à la facturation, aux paiements et au suivi comptable	Logiciel comptable interne, transferts bancaires, partenaire bancaire

4.3 Échelle de gravité retenue

Niveau	Description
G1 – Mineur	Le centre peut absorber les conséquences sans perturbation importante.
G2 – Significatif	Le centre peut maintenir son activité, mais avec des contraintes notables.
G3 – Grave	Le centre fait face à des difficultés majeures pour poursuivre normalement son activité.
G4 – Critique	La continuité d'activité, la sécurité des données ou la confiance des patients est fortement remise en cause.

4.4 Événements redoutés

Événement redouté	Valeur impactée	Gravité	Justification
Extraction massive des dossiers patients	Dossiers patients	G4	Les données de santé sont particulièrement sensibles. Une fuite entraînerait une perte de confiance, des obligations de notification et un risque de sanction réglementaire.
Altération frauduleuse des dossiers patients	Dossiers patients	G4	Une modification non autorisée peut compromettre la qualité du suivi médical et engager la responsabilité du centre.

Indisponibilité prolongée de Hellodoc	Consultations	G3	L'accès aux dossiers serait fortement dégradé, avec un impact direct sur les consultations et les télétransmissions.
Compromission des télétransmissions	Télétransmission	G3	Une atteinte à ce processus pourrait provoquer des pertes financières, des erreurs de remboursement et des litiges administratifs.
Interruption du service Doctolib	Prise de rendez-vous	G2	L'activité serait perturbée, mais un mode de fonctionnement alternatif par téléphone resterait possible.
Publication d'une fuite de données	Réputation	G3	Une exposition publique des données nuirait à l'image du centre, pourrait entraîner le départ de patients et provoquer une médiatisation locale.
Perte ou indisponibilité des sauvegardes	Continuité et dossiers patients	G4	L'absence de sauvegardes exploitables empêcherait une restauration rapide après panne, erreur humaine ou attaque par rançongiciel.

4.5 Socle de sécurité existant

Le niveau de sécurité actuel présente plusieurs fragilités importantes. Les informations disponibles montrent qu'un antivirus est installé sur les postes, mais que plusieurs mesures essentielles restent absentes ou insuffisamment maîtrisées : utilisation de comptes partagés, mots de passe faibles, réseau Wi-Fi non segmenté, absence de pare-feu professionnel, sauvegardes non chiffrées, hébergement des sauvegardes cloud chez un prestataire non certifié HDS, absence de sensibilisation du personnel et absence de PCA/PRA formalisé.

Mesure existante	Statut	Commentaire
Antivirus sur les postes	En place	Protection de base utile, mais insuffisante contre le phishing, les mots de passe faibles et les déplacements latéraux.
Authentification Hellodoc	Partiel	L'utilisation de comptes ou mots de passe partagés limite l'imputabilité et la traçabilité des actions.
Pare-feu réseau professionnel	Absent	La protection repose principalement sur la box Internet, sans filtrage avancé ni règles de sécurité documentées.
Chiffrement des sauvegardes	Absent	Les sauvegardes réalisées sur disque externe ne bénéficient pas d'un chiffrement identifié.
Hébergement conforme HDS	Non conforme	Selon le cas d'étude, les sauvegardes cloud sont hébergées chez un prestataire grand public non certifié HDS.
Sensibilisation du personnel	Absent	Aucune action de formation ou de sensibilisation cybersécurité n'est formalisée.
Plan de continuité / reprise	Absent	Aucun dispositif documenté ne précise les actions à mener en cas d'incident majeur.
Séparation Wi-Fi personnel / patients	Absent	L'existence d'un Wi-Fi unique augmente le risque d'exposition du réseau interne.
Tests de restauration	Non précisé	Les sauvegardes sont mentionnées, mais aucune preuve de test de restauration régulier n'est fournie.

5 Atelier 2 – Sources de risque

5.1 Objectif de l'atelier

L'atelier 2 identifie les sources de risque crédibles pour le centre et les objectifs qu'elles pourraient poursuivre. Les couples source de risque / objectif visé sont ensuite évalués afin de sélectionner ceux qui doivent être approfondis dans les scénarios stratégiques. La démarche ne recherche pas l'exhaustivité : elle privilégie les acteurs et motivations les plus plausibles au regard du contexte du centre.

5.2 Cartographie des sources de risque

Source de risque	Pertinence	Justification pour Saint-Antoine
Cybercriminel organisé (rançongiciel)	Très élevée	Le secteur de la santé constitue une cible attractive en raison de la criticité des activités et de la sensibilité des données.
Cybercriminel opportuniste	Élevée	Les campagnes de phishing, fraudes au paiement et compromissions de comptes sont fréquentes et peu coûteuses pour l'attaquant.
Concurrent malveillant	Faible	La structure ne présente pas d'enjeu concurrentiel majeur susceptible de justifier une attaque ciblée.
État ou groupe soutenu par un État	Non pertinent	Aucun enjeu géopolitique, stratégique ou de souveraineté particulier n'est identifié dans le cas d'étude.
Hacktiviste	Faible	Le centre ne porte pas de position publique ou politique connue qui augmenterait significativement ce risque.
Employé malveillant	Moyenne	Le faible effectif et les accès partagés peuvent faciliter un acte de vengeance, une fraude ou une extraction de données.
Employé négligent	Élevée	L'absence de sensibilisation, les comptes partagés et l'usage possible de supports amovibles augmentent le risque d'erreur.
Prestataire compromis	Moyenne	Les accès de maintenance, Hellodoc, Doctolib et le prestataire de sauvegarde constituent des dépendances externes importantes.

5.3 Objectifs visés associés

Source de risque	Objectif visé
Cybercriminel organisé	Obtenir un gain financier par rançon, extorsion ou revente des données patients.
Cybercriminel opportuniste	Détourner des télétransmissions, commettre une fraude bancaire ou exploiter des comptes compromis.
Employé négligent	Aucun objectif malveillant : exposition ou altération involontaire de données par erreur de manipulation.
Employé malveillant	Se venger après un conflit, frauder ou revendre des données auxquelles il a accès.
Prestataire compromis	Permettre à un attaquant externe de pivoter vers le centre par la chaîne d'approvisionnement.

5.4 Couples source de risque / objectif visé

COUPLE SR/OV	OBJECTIF VISÉ	VRAISEM- BLANCE	RETENU POUR ATELIER 3 ?
Cybercriminel organisé / Rançon	Gain financier par rançon ou extorsion	Très élevée	Oui — priorité absolue
Cybercriminel organisé / Revente de données	Gain financier par revente des données patients	Élevée	Oui
Employé négligent / Exposition involontaire	Aucun objectif malveillant — exposition par erreur	Élevée	Oui
Cybercriminel opportuniste / Fraude Sécu	Détournement des télétransmissions Sécu ou fraude bancaire	Moyenne	Optionnel
Prestataire compromis / Pivot	Pivot vers la cible finale via la chaîne d'approvisionnement	Moyenne	Optionnel comme couple autonome ; intégré à SS2 comme chemin d'attaque
Employé malveillant / Vengeance	Vengeance après conflit ou revente de données	Faible	Non retenu

6 Atelier 3 – Scénarios stratégiques

6.1 Objectif de l'atelier

L'atelier 3 décrit les chemins d'attaque à haut niveau, sans entrer dans le détail des techniques employées. Chaque scénario relie un couple source de risque / objectif visé à un ou plusieurs événements redoutés, puis fait l'objet d'une cotation de vraisemblance sur quatre niveaux.

6.2 SS1 – Rançongiciel via phishing

Source de risque : cybercriminel organisé

Objectif visé : gain financier par rançon

Le cybercriminel adresse un courriel de phishing à une secrétaire médicale en se faisant passer pour la CPAM. L'ouverture de la pièce jointe installe un malware sur le poste. Celui-ci se propage ensuite via les partages internes jusqu'au serveur Hellodoc. Le chiffrement des données médicales provoque l'indisponibilité des consultations et place la direction sous contrainte.

Événements redoutés atteints : indisponibilité prolongée de Hellodoc (G3) et vol potentiel des dossiers patients (G4).

Vraisemblance : V4 – Très élevée.

6.3 SS2 – Compromission via prestataire

Source de risque : cybercriminel organisé

Objectif visé : revente de données patients

L'attaquant compromet un prestataire informatique ou cloud utilisé par le centre, puis exploite un accès légitime ou insuffisamment contrôlé pour atteindre Hellodoc ou les sauvegardes. L'exfiltration peut rester discrète pendant plusieurs semaines avant d'être détectée.

Événements redoutés atteints : vol massif des dossiers patients (G4) et diffusion publique de la fuite (G3).

Vraisemblance : V3 – Élevée.

6.4 SS3 – Exposition par négligence interne

Source de risque : employé négligent

Objectif visé : aucun objectif malveillant ; exposition involontaire

Une secrétaire connecte une clé USB personnelle potentiellement infectée ou transfère des données vers un espace non autorisé. En parallèle, les mots de passe partagés entre médecins peuvent rester connus après un changement de personnel. L'accumulation de ces pratiques expose les dossiers patients à une consultation, une modification ou une extraction non autorisée.

Événements redoutés atteints : modification frauduleuse possible des dossiers patients (G4) et vol de données (G4).

Vraisemblance : V3 – Élevée.

6.5 Synthèse des scénarios stratégiques retenus

N°	Scénario	Vraisemblance	Gravité maximale
SS1	Rançongiciel via phishing	V4 – Très élevée	G4
SS2	Compromission via prestataire	V3 – Élevée	G4
SS3	Exposition par négligence	V3 – Élevée	G4

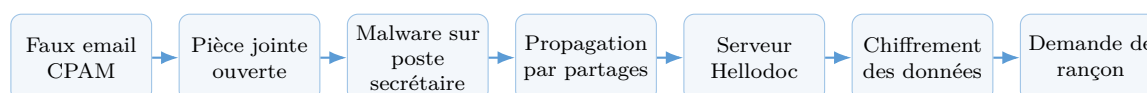
7 Atelier 4 – Scénarios opérationnels

7.1 Principe de lecture

Les scénarios opérationnels détaillent les chemins d'attaque retenus à partir des scénarios stratégiques. Les techniques mentionnées sont alignées avec MITRE ATT&CK afin de donner un langage commun aux équipes techniques et aux prestataires. Les identifiants sont utilisés comme repères défensifs, non comme mode d'emploi offensif.

7.2 SO1 – Rançongiciel via phishing CPAM

Le scénario SO1 est le plus critique, car il combine une vraisemblance élevée et un impact direct sur la continuité des soins.



Phase	Action de l'attaquant	Bien support visé	MITRE	Signaux de détection	Mesures de contrôle
Reconnaissance	Collecte d'informations publiques sur le centre, ses activités et son secrétariat.	Présence en ligne, site, Doctolib	T1593	Recherches ouvertes difficiles à voir côté victime.	Limitier l'exposition d'informations nominatives inutiles.
Préparation du leurre	Création d'un faux message CPAM avec pièce jointe crédible.	Messagerie	T1566.001	Domaine proche de la CPAM, formulation urgente.	Filtrage mail, analyse des pièces jointes, bannière externe.
Délivrance	Envoi du message au secrétariat.	Boîte mail secrétaire	T1566.001	Réception d'un email externe atypique.	Politique de messagerie, SPF/DKIM/DMARC si possible.
Exécution	Ouverture de la pièce jointe par l'utilisateur.	Poste secrétaire	T1204.002	Processus anormal après ouverture, alerte antivirus/EDR.	Sensibilisation utilisateur, blocage des macros et exécutions à risque.
Persistance	Création d'un mécanisme de relance.	Système Windows	T1053.005	Tâche planifiée inconnue, modification système.	Durcissement poste, EDR, revue des tâches planifiées.
Réutilisation des accès	Exploitation de mots de passe faibles ou partagés.	Comptes locaux, comptes Hellodoc	T1078	Connexions anormales, compte utilisé hors contexte.	Comptes nominatifs, politique d'habilitation, MFA si possible.
Mouvement latéral	Propagation via les partages internes.	Réseau interne, partages, serveur Hellodoc	T1021.002 / T1080	Pic d'accès SMB, modifications massives de fichiers.	Segmentation réseau, restriction des partages, moindre privilège.
Action sur l'objectif	Chiffrement des données et dépôt d'une note de rançon.	Hellodoc, dossiers patients, sauvegardes accessibles	T1486	Renommage massif, indisponibilité brutale.	Sauvegardes isolées, PRA, procédure de crise, déconnexion rapide.

Vraisemblance opérationnelle : V4 – Très élevée. Les étapes reposent sur des techniques courantes et le socle actuel comporte peu de barrières capables d'interrompre la chaîne d'attaque.

7.3 SO2 – Compromission via prestataire

Ce scénario repose sur un accès de maintenance ou un service tiers utilisé comme vecteur d'intrusion. Il est cohérent avec les techniques MITRE relatives à la chaîne d'approvisionnement et aux accès distants légitimes : T1195, T1219, T1133, T1078, T1005 et T1567.002.

Phase	Action de l'attaquant	Bien support visé	MITRE	Signaux de détection	Mesures de contrôle
Reconnaissance	Identification du prestataire intervenant sur Hellodoc ou les sauvegardes.	Documentation publique, organisation du centre	T1593	Faible visibilité côté centre.	Réduire les informations publiques non nécessaires.
Compromission du prestataire	Hameçonnage ou compromission d'un technicien.	SI du prestataire	T1195 / T1566	Anomalies côté prestataire, souvent invisibles côté client.	Clauses contractuelles, exigences de sécurité, revue du tiers.
Accès aux outils légitimes	Usage d'un outil de prise en main à distance ou d'un compte technique.	Outils de maintenance	T1219 / T1078	Usage hors fenêtre de maintenance, adresse IP inhabituelle.	Comptes nominatifs prestataires, MFA, accès temporaires.
Pivot vers le centre	Connexion à distance vers l'environnement Saint-Antoine.	Serveur Hellodoc, passerelle distante	T1133	Session hors horaire, source anormale.	Journalisation fine, liste blanche d'IP si possible.
Collecte	Consultation des bases et répertoires sensibles.	Données patients	T1005	Requêtes ou copies inhabituelles.	Limitation des droits, segmentation, alertes d'accès massif.
Exfiltration	Copie discrète progressive vers un espace externe.	Flux sortants, stockage cloud	T1567.002	Hausse des échanges sortants, usage cloud non prévu.	Contrôle des flux, revue des exports, chiffrement avant externalisation.

Vraisemblance opérationnelle : V3 – Élevée. Une compromission de la chaîne d'approvisionnement demeure difficile à détecter, notamment lorsque l'attaquant utilise des outils et des comptes légitimes.

7.4 SO3 – Exposition par négligence interne

Le scénario SO3 traduit moins une attaque sophistiquée qu'une accumulation de mauvaises pratiques facilitant l'incident : clé USB personnelle, comptes partagés, absence de journalisation, manque de sensibilisation.

Phase	Action ou événement	Bien support visé	MITRE	Signaux de détection	Mesures de contrôle
Vecteur d'entrée	Connexion d'une clé USB personnelle potentiellement infectée.	Poste utilisateur	T1091	Nouveau périphérique USB détecté.	Blocage ou contrôle des ports USB.
Exécution	Ouverture d'un fichier depuis la clé ou un dossier partagé.	Poste Windows	T1204.002	Exécution anormale, fichier inhabituel.	Antivirus/EDR, sensibilisation, restriction d'exécution.
Propagation	Dépôt ou copie dans un partage interne.	Partages, réseau local	T1080 / T1021.002	Fichiers anormaux dans des répertoires communs.	Revue des partages, cloisonnement.
Compromis aggravant	Utilisation d'un compte partagé divulgué ou non révoqué.	Comptes Hellodoc	T1078	Connexion après départ d'un collaborateur.	Procédure arrivée/départ, comptes nominatifs.
Accès aux données	Copie ou consultation non tracée de documents patients.	Dossiers patients, exports	T1005 / T1025	Copies inhabituelles, export volumineux.	Habilitations minimales, supervision des exports.
Modification / exfiltration	Modification d'un dossier ou transfert vers un cloud externe.	Données médicales	T1565.001 / T1567.002	Historique incohérent, flux externes.	Journalisation applicative, sensibilisation, contrôle des usages cloud.

Vraisemblance opérationnelle : V3 – Élevée. Le scénario combine plusieurs faiblesses humaines et techniques fréquentes dans une petite structure : supports amovibles, comptes partagés, habilitations insuffisantes et faible journalisation.

7.5 Synthèse de l'évaluation des risques

La vraisemblance opérationnelle est rapprochée de la gravité maximale des événements redoutés afin de positionner les scénarios sur l'échelle de risque retenue pour l'étude.

Scénario	Vraisemblance	Gravité	Niveau de risque
SO1 – Rançongiciel via phishing	V4 – Très élevée	G4	Critique
SO2 – Compromission via prestataire	V3 – Élevée	G4	Élevé
SO3 – Exposition par négligence	V3 – Élevée	G4	Élevé

8 Atelier 5 – Plan de traitement

8.1 Objectif de l'atelier

L'atelier 5 transforme l'analyse en plan d'action. Pour chaque scénario, il convient de choisir un mode de traitement parmi quatre possibilités : réduire le risque, refuser ou éviter l'activité à l'origine du risque, partager ou transférer une partie du risque, ou accepter le risque résiduel après décision formelle. Le plan ci-dessous privilégie des mesures proportionnées à la taille du centre et à la criticité des données de santé.

8.2 Modes de traitement retenus

Scénario	Mode retenu	Objectif du traitement
SO1 – Rançongiciel via phishing	Réduire	Diminuer simultanément la vraisemblance de compromission et la gravité d'une indisponibilité.
SO2 – Compromission via prestataire	Réduire et partager	Encadrer les tiers, mettre en conformité l'hébergement et transférer une partie de l'impact financier par assurance.
SO3 – Exposition par négligence	Réduire	Réduire la fréquence des erreurs et améliorer l'imputabilité des actions.

8.3 Plan de traitement pour SO1 – Rançongiciel via phishing

Mode de traitement : réduction de la vraisemblance et de la gravité.

Mesure	Type	Priorité	Délai
Sensibilisation annuelle obligatoire au phishing pour tout le personnel	Organisationnelle	P1	60 jours
Filtrage renforcé de la messagerie et analyse des pièces jointes	Technique	P1	60 jours
Déploiement d'une solution EDR sur les postes et le serveur lorsqu'elle est compatible	Technique	P1	60 jours
Comptes nominatifs et suppression des mots de passe partagés	Technique / organisationnelle	P1	30 jours
Mise en place de sauvegardes isolées et immuables selon une logique 3-2-1, avec test de restauration	Technique	P1	60 jours
Segmentation réseau entre postes, Wi-Fi invités et serveur Hellodoc	Technique	P2	6 mois
Formalisation d'une procédure de crise rançongiciel et d'un mode de fonctionnement dégradé	Organisationnelle	P2	6 mois
Plan de reprise d'activité testé au moins une fois par an	Organisationnelle	P2	6 mois

8.4 Plan de traitement pour SO2 – Compromission via prestataire

Mode de traitement : réduction du risque et partage partiel par assurance cyber.

Mesure	Type	Priorité	Délai
Audit initial puis revue annuelle des prestataires critiques et de leurs clauses de sécurité	Organisationnelle	P1	60 jours

Migration des sauvegardes vers un hébergeur certifié HDS et mise en conformité contractuelle	Juridique / conformité	P1	60 jours
MFA sur tous les accès prestataires lorsque techniquement possible	Technique	P1	60 jours
Limitation stricte des droits de maintenance et activation d'accès temporaires	Technique	P1	60 jours
Journalisation et revue des connexions prestataires	Technique	P2	6 mois
Fenêtres de maintenance formalisées et approuvées	Organisationnelle	P2	6 mois
Revue périodique des comptes techniques et révocation des accès inutiles	Organisationnelle	P2	6 mois
Étude puis souscription d'une assurance cyber adaptée au secteur santé	Financière	P2	6 mois

8.5 Plan de traitement pour SO3 – Exposition par négligence interne

Mode de traitement : réduction de la vraisemblance.

Mesure	Type	Priorité	Délai
Suppression des comptes partagés et création de comptes nominatifs	Technique	P1	30 jours
Politique de mots de passe documentée et alignée sur les recommandations ANSSI applicables	Organisationnelle	P1	60 jours
Blocage ou contrôle des ports USB sur les postes sensibles	Technique	P1	60 jours
Charte informatique signée par tous les collaborateurs	Organisationnelle	P1	60 jours
Procédure formalisée d'arrivée, de mobilité et de départ	Organisationnelle	P1	60 jours
Sensibilisation aux erreurs de manipulation, aux envois erronés et aux usages cloud non autorisés	Organisationnelle	P2	6 mois
Traçabilité minimale des accès, modifications et exports Hellodoc	Technique	P2	6 mois
Verrouillage automatique des sessions et principe du moindre privilège	Technique	P2	6 mois

8.6 Risque résiduel estimé et décision d'acceptation

Après mise en œuvre des mesures, le risque est réévalué. L'acceptabilité présentée ci-dessous constitue une proposition : la décision finale d'acceptation appartient à la direction du centre et doit être formalisée.

Scénario	Risque initial	Risque résiduel	Acceptable ?	Condition d'acceptation
SO1 – Rançongiciel via phishing	Critique	Modéré	Oui	Mise en œuvre des mesures P1, sauvegardes restaurables et validation formelle par la direction.
SO2 – Compromission via prestataire	Élevé	Modéré	Oui	Hébergement HDS, MFA, contrôle des accès tiers et clauses contractuelles vérifiées.

SO3 – Exposition par négligence	Élevé	Faible	Oui	Comptes nominatifs, contrôle USB, charte signée et procédure de gestion des habilitations appliquée.
---------------------------------	-------	--------	-----	--

9 Conclusion et recommandations

Le Centre Médical Saint-Antoine n'a pas besoin, à court terme, d'un programme cybersécurité complexe. Il a surtout besoin d'un socle minimum sérieux, appliqué et suivi dans le temps. Les priorités sont claires : mettre fin aux comptes partagés, déployer une protection EDR adaptée, sécuriser les sauvegardes selon une logique 3-2-1, migrer les sauvegardes cloud vers un hébergeur certifié HDS, encadrer les prestataires, sensibiliser les utilisateurs et formaliser une capacité de reprise d'activité.

La direction doit valider un lot de mesures P1 à engager dans les 60 jours. Ce premier lot doit être porté par un référent sécurité interne, même si celui-ci n'est pas un spécialiste cybersécurité à temps plein. Son rôle sera de suivre les actions, de faire le lien avec le prestataire informatique et de remonter les arbitrages nécessaires à la direction.

Les décisions à prendre en priorité sont les suivantes :

- valider le plan de traitement P1 ;
- désigner un référent sécurité interne ;
- revoir les contrats et accès des prestataires ;
- sécuriser les sauvegardes selon une logique 3-2-1 et vérifier leur restaurabilité ;
- migrer les sauvegardes cloud vers un hébergeur certifié HDS ;
- déployer une protection EDR compatible sur les postes et le serveur ;
- supprimer les comptes partagés ;
- mettre en place une charte informatique et une procédure d'arrivée/départ ;
- lancer une première sensibilisation phishing ;
- préparer un mode de fonctionnement dégradé en cas d'incident.

Cette trajectoire permet de réduire rapidement les risques les plus critiques sans imposer au centre une transformation disproportionnée. Elle rend surtout la structure plus résiliente face aux incidents les plus plausibles : rançongiciel, fuite de données, erreur humaine et compromission par un tiers.

10 Annexes

10.1 Références institutionnelles

- ANSSI – Méthode EBIOS Risk Manager : <https://cyber.gouv.fr/la-methode-ebios-risk-manager>
- CNIL – Guide de la sécurité des données personnelles : <https://www.cnil.fr/fr/guide-de-la-securite-des-donnees-personnelles>
- Légifrance – Article L1111-8 du Code de la santé publique : https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000033862549
- MITRE ATT&CK Enterprise : <https://attack.mitre.org/>

10.2 Techniques MITRE ATT&CK utilisées

Technique	Libellé	Usage dans le rapport
T1593	Search Open Websites/Domains	Reconnaissance du centre ou des prestataires.
T1566.001	Spearphishing Attachment	Phishing CPAM avec pièce jointe malveillante.
T1204.002	User Execution : Malicious File	Ouverture d'un fichier malveillant par un utilisateur.
T1053.005	Scheduled Task	Persistance via tâche planifiée.
T1078	Valid Accounts	Usage de comptes valides, faibles ou partagés.
T1021.002	SMB/Windows Admin Shares	Propagation via partages Windows.
T1080	Taint Shared Content	Contamination de contenus partagés.
T1486	Data Encrypted for Impact	Chiffrement de données dans un scénario de rançongiciel.
T1195	Supply Chain Compromise	Compromission via prestataire.
T1219	Remote Access Tools	Usage d'outils de prise en main à distance.
T1133	External Remote Services	Accès distant de maintenance.
T1005	Data from Local System	Collecte de données locales.
T1025	Data from Removable Media	Données depuis un support amovible.
T1565.001	Stored Data Manipulation	Modification de données stockées.
T1567.002	Exfiltration to Cloud Storage	Exfiltration vers un service cloud.
T1091	Replication Through Removable Media	Propagation ou incident via support USB.

10.3 Glossaire court

Bien support	Élément technique ou organisationnel qui porte concrètement une valeur métier.
Événement redouté	Conséquence que l'organisation souhaite éviter en raison de son impact.
HDS	Cadre applicable à l'hébergement de données de santé à caractère personnel.
Hellodoc	Logiciel médical central pour la gestion des dossiers patients du centre.
PCA/PRA	Plan de continuité d'activité et plan de reprise d'activité.
Source de risque	Acteur ou cause susceptible de porter atteinte aux valeurs métier.
SR/OV	Couple source de risque / objectif visé, utilisé dans l'atelier 2 EBIOS RM.